第 18 章 无线网络安全

0. 学习目标总览

教材给出本章五个学习目标：

1. 概述无线网络的安全威胁和对策。
2. 了解企业网络使用移动设备时的安全威胁。
3. 描述移动设备安全策略中的主要元素。
4. 了解IEEE 802.11无线局域网络标准的基本元素。
5. 小结IEEE 802.11i无线局域网安全架构的各个组成元素。

本章主线是从开放无线介质到 RSN 的分阶段保护：

```
无线环境
 |-- 广播信道、移动性、资源受限、物理易接近
 |
 |-- 移动设备安全
 |     |-- 设备安全
 |     |-- 数据流安全
 |     `-- 屏障安全
 |
 |-- IEEE 802.11
 |     |-- STA / AP / BSS / DS / ESS
 |     `-- MAC、物理层与关联服务
 |
 `-- IEEE 802.11i RSN
       |-- 发现
       |-- 认证
       |-- 密钥生成与分发
       |-- 受保护数据传输
       `-- 连接终止
```

1. 学习目标 1：无线网络安全威胁和对策

1.1 无线环境的风险来源



图 18.1　无线网络的组成

图 18.1 无线网络的组成

无线网络的攻击面来自三个部分：无线客户端/端点、无线接入点（AP）和广播无线介质。相较有线网络，风险更高的原因是：

因素	安全影响
信道	广播通信易被窃听、干扰和主动利用。
移动性	设备可离开受控区域，带来丢失、窃取和跨网络使用风险。

因素	安全影响
资源	智能手机、传感器等资源受限，易受 DoS 和恶意软件影响。
易接近性	无人照管或敌占区域中的设备更容易遭受物理攻击。

1.2 无线网络威胁

- **意外关联**：覆盖范围重叠，用户误连相邻网络，导致资源暴露。
- **恶意关联**：攻击者伪装合法 AP，窃取口令后再通过合法 AP 进入有线网络。
- **自组网络和非传统网络**：缺乏中央控制，蓝牙、传感器等链路易受窃听和欺骗。
- **身份盗窃（MAC 欺骗）**：监听并复制合法设备的 MAC 地址。
- **中间人攻击**：让用户和 AP 误以为彼此通信，实际都连接到攻击设备。
- DoS：不断发送请求资源的无线协议消息，耗尽 AP 或端口资源。
- **网络注入**：向暴露的 AP 注入路由、管理或伪造重置消息，降低网络性能。

1.3 无线安全措施

保护对象	主要措施
无线传输	隐藏或缩小信号覆盖、使用定向天线和屏蔽；对所有传输加密；用认证协议防止修改和插入；通过现场调查、频率规划和信号控制降低 DoS。
接入点	使用 IEEE 802.1X 基于端口的访问控制，防止恶意 AP 和未授权设备形成后门。
无线网络及端点	加密路由器数据流；安装防病毒、反间谍软件、防火墙和入侵检测/阻止；关闭标识广播、修改默认标识和管理口令；限制允许的 MAC 地址。

MAC 地址过滤只能作为策略的一部分，因为 MAC 地址可以被欺骗；真正的访问控制还需依赖认证和密钥机制。

> MAC地址是固化在硬件上的物理标识（静态的），但在网络通信中，它是以**明文形式**出现在数据链路层帧头部的。
> 而认证和密钥机制依赖的是**密码学证据**，具有动态性和即时性。攻击者的攻击成本远大于收益。

2. 学习目标 2：企业使用移动设备的安全威胁

企业网络从“受控 PC + 数据中心 + 静态边界”转向移动设备、云应用、虚拟服务器和外部合作伙伴共存的环境，网络边界随用户角色、位置、设备和时间动态变化。

2.1 移动设备的七类威胁

1. 缺少物理安全控制：设备丢失或被窃后，攻击者可读取本地数据或利用设备访问企业资源。
2. 使用不可信移动设备：个人设备可能未加密，或安全操作系统已被绕过。
3. 使用不可信网络：远程 Wi-Fi、蜂窝网络和其他外部网络容易遭受窃听和中间人攻击。
4. 使用未知方创建的应用：第三方应用可能包含恶意软件。
5. 与其他系统交互：自动同步联系人、照片、文档和云存储，可能把企业数据复制到不安全位置。
6. 使用不可信内容：恶意 QR 码可能引导设备访问恶意 URL。
7. 使用位置服务：GPS 信息可能暴露设备和使用者的实际位置。

3. 学习目标 3：移动设备安全策略中的主要元素

3.1 移动设备安全策略

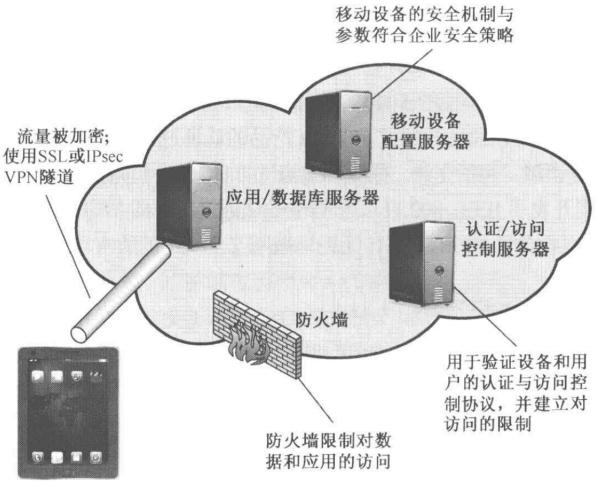


图 18.2　移动设备安全元素

图 18.2 移动设备安全元素

安全策略分为设备安全、数据流安全和屏障安全三类：

类别	主要控制
设备安全	自动锁定、PIN/口令、禁止自动填充；远程清除和禁用；及时更新系统与应用；反病毒；敏感数据不本地存储或加密存储；限制第三方应用、采用白名单或沙箱；限制云同步；用数字签名和公钥证书验证应用；按策略限制摄像头、位置服务和越狱/Root 设备。
数据流安全	使用 SSL、IPsec/VPN 等加密全部移动设备—企业流量；采用设备认证与用户认证的双层认证。
屏障安全	使用专用防火墙、入侵检测和入侵阻止系统限制移动设备可访问的数据和应用。

4. 学习目标 4：IEEE 802.11 无线局域网标准的基本元素

4.1 Wi-Fi 与协议架构

> 概念补充：什么是协议

Wi-Fi 联盟最初解决不同厂商 802.11b 产品的互操作认证，后来扩展到其他 802.11 产品和安全认证。WPA2 整合了 IEEE 802.11i 的完整功能。

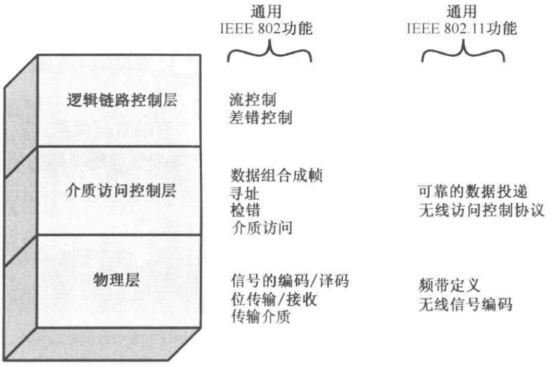


图 18.3 IEEE 802.11 协议栈

图 18.3 IEEE 802.11 协议栈

层	作用
物理层	信号编码/译码、位传输/接收、传输介质、频带和天线特性。
MAC 层	将上层数据封装为带地址和校验字段的 MPDU，接收时执行地址识别、错误检测和介质访问控制。
LLC 层	跟踪成功接收的帧，并重发未成功的帧；MAC 主要负责检测错误和丢弃帧。

通用 MPDU 由 MAC 控制、目的 MAC 地址、源 MAC 地址、MSDU 和 CRC/FCS 组成；CRC 只提供检错，不提供密码学完整性。

4.2 网络构成与术语

术语	含义
STA（基站）	符合 IEEE 802.11 MAC 和物理层标准的设备。
AP（接入点）	具有基站功能并通过无线介质提供分布式系统访问的实体。
BSS	由单个协调功能控制的一组基站，是 **WLAN 的最小组成单元**。
IBSS	没有 AP、基站彼此直接通信的独立自组 BSS。
DS	互连 BSS 并集成 LAN 的分布式系统。
ESS	由 DS 互连的两个或多个 BSS，对 LLC 层表现为单个逻辑 LAN。
MPDU	对等 MAC 实体之间交换的数据单元。
MSDU	在 MAC 用户之间传输的信息单元。

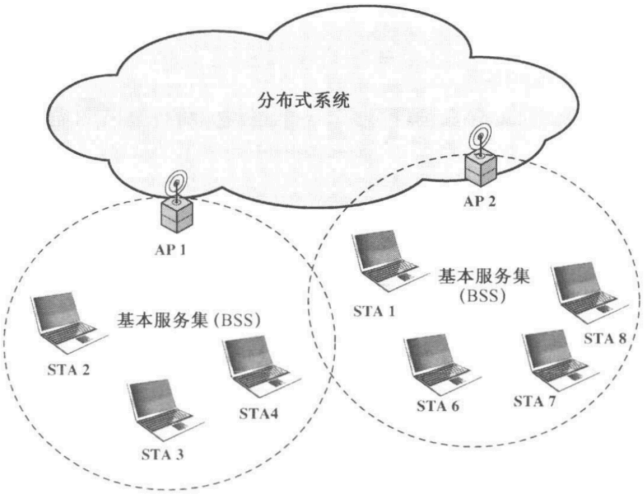


图 18.5　IEEE 802.11 扩展服务集

图 18.5 由多个 BSS、AP 和 DS 组成的 ESS

BSS 中的 STA 通常通过 AP 转发彼此或跨 BSS 的帧；IBSS 中 STA 直接通信。关联服务使 DS 知道基站当前属于哪个 AP，重新关联支持从一个 BSS 漫游到同一 ESS 的另一个 BSS，解除关联用于终止已有关系。

4.3 IEEE 802.11 服务

802.11 定义关联、认证、解除认证、解除关联、分发、整合、MSDU 发送、隐私和重新关联九类服务。基站服务由 STA/AP 实现，分布式服务在 BSS 之间提供；认证、解除认证和隐私主要控制访问与安全，其余服务支持 MSDU 传输。

5. 学习目标 5：IEEE 802.11i 无线局域网安全架构

5.1 RSN 服务与元素

原始 WEP 的隐私和认证存在严重缺陷。Wi-Fi 联盟先发布 WPA，IEEE 802.11i 的最终鲁棒安全网络规范称为 RSN，WPA2 用于认证符合完整 802.11i 的产品。

RSN 提供三类服务：

1. **认证**：STA 与认证服务器 AS 交互，完成相互认证并生成 STA/AP 使用的临时密钥。
2. **访问控制**：强化认证、路由控制和密钥交换。
3. **隐私与完整性**：对 MAC 层数据和 MIC 一起加密，防止窃听和修改。

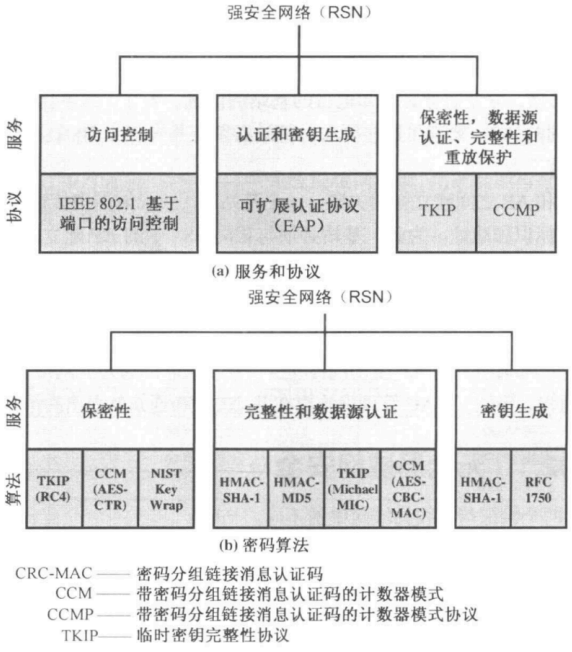


图 18.6　IEEE 802.11i 的元素

图 18.6 IEEE 802.11i 的服务、协议和密码算法

单播数据可使用 TKIP 或 CCMP；认证和密钥管理可使用 IEEE 802.1X/EAP、预共享密钥或供应商专用机制。

5.2 五个操作阶段

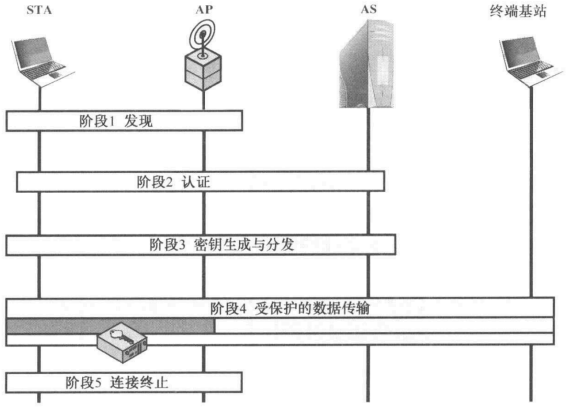


图 18.7　IEEE 802.11i 的各个操作阶段

图 18.7 IEEE 802.11i 的五个操作阶段

1. **发现**：AP 用 Beacon 和 Probe Response 公布安全策略，STA 识别 AP，协商密码套件和认证机制并关联。

2. **认证**：STA 与 AS 相互证明身份；认证成功前，AP 阻塞普通数据流，只转发认证控制流。
3. **密钥生成与分发**：STA 和 AP 生成并安装单播与组播所需密钥。
4. **受保护数据传输**：通过 AP 转发受保护帧；802.11i 主要保护 STA—AP 链路，不自动提供端到端安全。
5. **连接终止**：拆除安全连接，回到初始状态。

> **关于这五个阶段的理解**
>
> 这五个阶段正是一个**新STA（终端站点）进入BSS（基本服务集）时，AP和AS对其执行的一套强制性"准入验证与安全通道建立流程"**。
>
> 802.11i的这套五阶段流程，是专门针对**基础设施BSS（Infrastructure BSS）** 场景设计的，用于解决**STA与AP之间那一段无线链路**的安全问题。它确保了一个新STA入网时，身份必须经过AS验证，且数据必须在AP的控制下加密传输。

5.3 发现与认证阶段

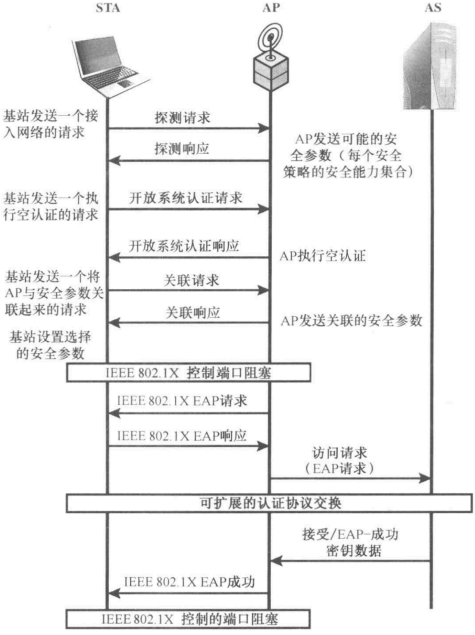


图 18.8　IEEE 802.11i 操作的各个阶段：性能发现、认证和交互

图 18.8 IEEE 802.11i 的发现、认证和交互

发现阶段目的是让 STA 和 AP 相互识别，协商安全功能配置，并用这些安全功能为未来的通信建立关联。

发现阶段协商三类技术：单播保密性/MPDU 完整性协议、认证方法和密钥管理方法。密码套件可为 WEP、TKIP、CCMP 或厂商方案；AKM 套件可为 IEEE 802.1X、预共享密钥或厂商方案。

发现阶段包含网络性能发现、开放系统认证和关联。开放系统认证本身不提供安全，只为兼容状态机交换标识；关联请求选择匹配的认证/密钥管理套件、单播密码套件和组密钥套件，不匹配则拒绝关联并保持受控端口阻塞。

认证阶段目的是只允许授权基站使用网络，并向 STA 保证它连接的是一个合法网络。

认证阶段使用 IEEE 802.1X 基于端口的访问控制和 EAP。角色为请求者（STA）、认证器（AP）和认证服务器（AS）。不受控端口允许 STA 与 AS 交换认证 PDU，受控端口只有在认证授权后才允许普通数据流。

典型 EAP/RADIUS 流程为：

1. AP 向 STA 发送 EAP Request/Identity。
2. STA 返回 EAP Response/Identity，AP 经 RADIUS 封装为 Access-Request 发给 AS。
3. AS 返回 Access-Challenge，AP 转为 EAP Request 发给 STA。
4. STA 持续返回 EAP Response，步骤 3、4 可按 EAP 方法重复。
5. AS 返回 Access-Accept，AP 发 EAP Success；但受控端口要等 4 次握手安装密钥后才开放。

5.4 密钥、数据保护与 PRF

5.4.1 密钥层次

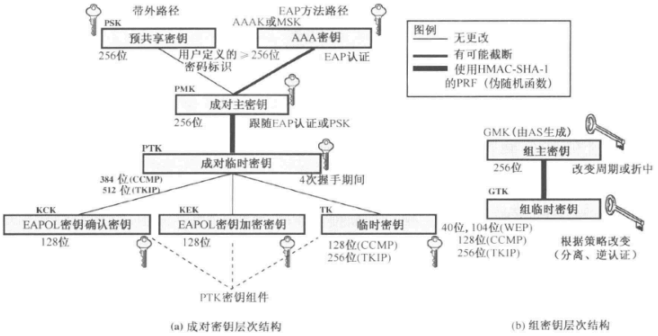


图 18.9　IEEE 802.11i 密钥层次

图 18.9 IEEE 802.11i 密钥层次

成对密钥的顶层可以是 PSK 或认证阶段生成的 MSK/AAAK。二者都得到 PMK，再由 PMK 生成 PTK。PTK 包括：

子密钥	作用
EAPOL-KCK	保护 4 次握手控制帧的完整性并证明持有 PMK。
EAPOL-KEK	加密 GTK 和握手中的其他密钥内容。
TK	保护 STA 与 AP 之间用户数据流。

组密钥从 GMK 生成 GTK，由 AP 安全分发给多播组 STA；每当设备离开网络，GTK 应改变。PMK/PSK、地址和时变值共同参与密钥派生，使每个 STA/AP 对拥有独特的下层密钥。

> **成对密钥和主密钥**
>
> **成对密钥（Pairwise Key）** 用于保护“一对一”的单播通信，而**组密钥（Group Key）** 用于保护“一对多”的广播/组播通信。

5.4.2 4 次握手与组密钥握手

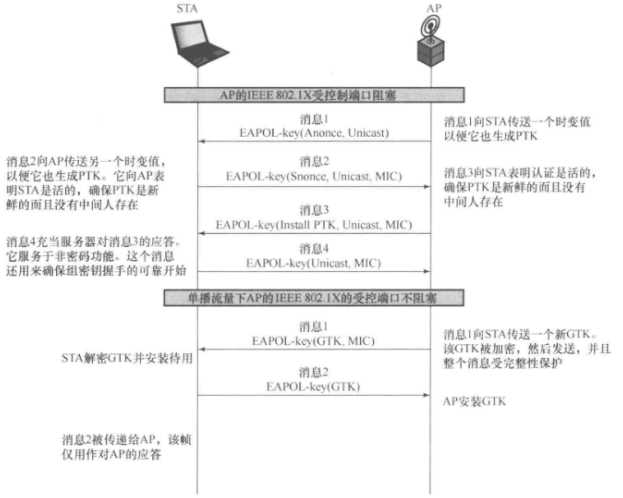


图 18.10　IEEE 802.11i 的操作阶段：4 次握手和组密钥握手

图 18.10 IEEE 802.11i 的 4 次握手和组密钥握手

4 次握手的目的：确认双方拥有 PMK、确认协商的密码套件，并生成新 PTK。

1. AP → STA：发送 AP 地址和随机数 `Anonce`。
2. STA → AP：生成 `Snonce`，用 PMK、两方地址和两个 nonce 生成 PTK，发送地址、`Snonce` 和由 KCK 保护的 MIC。
3. AP → STA：AP 生成相同 PTK，发送带 MIC 的安装消息。
4. STA → AP：发送受 MIC 保护的确认消息，双方安装密钥并开放受控端口。

组密钥握手中，AP 用 KEK 加密 GTK 并附 MIC 发送；STA 解密安装后回送受 MIC 保护的确认。

5.4.3 TKIP 与 CCMP

方案	完整性	保密性	重放保护
TKIP	用 Michael 根据地址、数据和密钥生成 64 位 MIC。	用 RC4 加密 MPDU 和 MIC；256 位 TK 中的部分材料用于 MIC，剩余材料形成 RC4 密钥。	每帧递增 TSC，受 MIC 保护并参与动态密钥生成。
CCMP	使用 CBC-MAC。	使用 AES-CTR。	用 48 位数据包号构造 nonce。

CCMP 使用 128 位 AES 密钥同时支持保密性和完整性，是新硬件设备的主要方案；TKIP 主要为旧 WEP 设备提供软件升级路径。

5.4.4 IEEE 802.11i PRF

IEEE 802.11i PRF 使用 HMAC-SHA-1 生成任意长度伪随机位流，形式为 $\mathrm{PRF}(K, A, B, \mathrm{Len})$：

- K 是秘密密钥；
- A 是用途标签，如 `Pairwise key expansion`；
- B 是地址、nonce 或时间等上下文；
- `Len` 是输出位数。

例如，CCMP 成对临时密钥：

$$\mathrm{PTK} = \mathrm{PRF}\Big(\mathrm{PMK}, \text{“Pairwise key expansion”}, \min(\text{AP-Addr}, \text{STA-Addr}) \parallel \max(\text{AP-Addr}, \text{STA-Addr}) \parallel \min(\text{Anonce}$$

PRF 的迭代为：

$$\begin{aligned} R &= \varepsilon \\ R &= R \parallel \text{HMAC-SHA-1}(K, A \parallel 0 \parallel B \parallel i), \\ & \quad i = 0, 1, \ldots, \left\lceil \frac{\text{Len}}{160} \right\rceil - 1 \\ \text{PRF}(K, A, B, \text{Len}) &= \text{Truncate}_{\text{Len}}(R) \end{aligned}$$

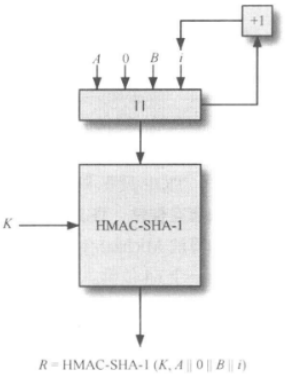


图 18.11　IEEE 802.11i 伪随机函数

图 18.11 IEEE 802.11i 伪随机函数

同一框架还可生成 nonce 和 GTK：

$$\text{Nonce} = \text{PRF}(\text{Random Number}, \text{“Init Counter”}, \text{MAC} \parallel \text{Time}, 256)$$

$$\text{GTK} = \text{PRF}(\text{GMK}, \text{“Group key expansion”}, \text{MAC} \parallel \text{Gnonce}, 256)$$

本章关键术语整理

术语	核心含义
无线网络	通过广播无线介质连接 STA、AP 和其他网络组件的网络。
AP	提供基站功能并把无线 BSS 接入 DS 的接入点。
STA	符合 IEEE 802.11 MAC 和物理层标准的无线设备。
BSS	由单个协调功能控制的一组基站。
IBSS	没有 AP、基站直接通信的独立 BSS。
DS	互连 BSS 并集成 LAN 的分布式系统。
ESS	通过 DS 互连、对 LLC 层表现为单个 LAN 的 BSS 集合。
MPDU	对等 MAC 实体之间交换的数据单元。
MSDU	MAC 用户之间传输的信息单元。
RSN	IEEE 802.11i 定义的鲁棒安全网络。
WPA/WPA2	Wi-Fi 联盟的无线安全认证体系；WPA2 整合 IEEE 802.11i 功能。
IEEE 802.1X	基于端口的网络访问控制标准。
EAP	IEEE 802.1X 使用的可扩展认证协议。

术语	核心含义
TKIP	使用 RC4、Michael MIC 和 TSC 的临时密钥完整性协议。
CCMP	使用 AES-CTR 和 CBC-MAC 的计数器模式 CBC-MAC 协议。
PSK	预共享密钥，可直接作为 PMK。
PMK	用于派生 PTK 的成对主密钥。
PTK	由 KCK、KEK 和 TK 组成的成对临时密钥。
GTK	由 GMK 生成、保护多播/广播数据的组临时密钥。
4 次握手	证明 PMK、协商套件并生成 PTK 的 STA/AP 消息交换。
PRF	用 HMAC-SHA-1 按用途标签和上下文扩展出伪随机密钥材料的函数。

学习目标自检

1. 能否从信道、移动性、资源和易接近性解释无线网络为何比有线网络更易受攻击？
2. 能否列出意外关联、恶意关联、MAC 欺骗、中间人、DoS 和网络注入等威胁，并为其匹配安全措施？
3. 能否区分移动设备的设备安全、数据流安全和屏障安全，并说明 BYOD、云同步和不可信应用带来的风险？
4. 能否解释 STA、AP、BSS、IBSS、DS、ESS、MPDU 和 MSDU 的含义及关系？
5. 能否说明 IEEE 802.11 物理层、MAC 层和 LLC 层分别承担什么功能？
6. 能否解释关联、重新关联、解除关联、分发和整合服务的作用？
7. 能否说明 WEP、WPA、WPA2、RSN 和 IEEE 802.11i 的演进关系？
8. 能否按发现、认证、密钥生成与分发、受保护数据传输、连接终止五阶段说明 RSN 操作？
9. 能否解释 IEEE 802.1X 中请求者、认证器、AS、不受控端口和受控端口的关系？
10. 能否区分 PSK/MSK、PMK、PTK、KCK、KEK、TK、GMK 和 GTK 的派生层次与用途？
11. 能否按四条消息描述 4 次握手，并说明 nonce、MAC 地址和 MIC 如何参与 PTK 生成与认证？
12. 能否比较 TKIP 与 CCMP 的完整性、保密性和重放保护机制，并写出 IEEE 802.11i PRF 的输入和迭代结构？